CYBERSECURITY INTERNSHIP ASSESSMENT

Week 11

SOC – Threat Detection, Alert Correlation & Incident Response

Security Operations Centre (SOC) analyst assessment report

Student name	PAILACHUKKA SUSMITHA
Internship / program	DG INTERNS HUB
Lab host / guest	Oracle VirtualBox / Ubuntu 26.04.1 LTS

Prepared for the Week 11 cybersecurity internship assessment: SOC threat detection, alert correlation and incident response.

Table of Contents

1. Executive Summary....4
1.1 Purpose of the Assessment....4
1.2 Learning Objectives....4
1.3 Tools and Lab Environment....4
1.4 Progress Summary....4
2. Introduction to the Security Operations Centre (SOC)....5
2.1 SOC Overview....5
2.2 Responsibilities of SOC Analysts....5
2.3 Analyst Tiers....5
3. Alert Correlation....6
3.1 What Is Alert Correlation?....6
3.2 Why Correlation Matters....6
3.3 Event vs Alert vs Incident....6
3.4 True Positive vs False Positive....6
3.5 Indicators of Compromise (IOCs)....7
3.6 Threat Detection vs Incident Response....7
3.7 Example: Correlating Multiple Security Events....7
4. Lab Environment and Tool Configuration....8
4.1 VirtualBox and Ubuntu Architecture....8
4.2 Wazuh Agent: Installation and Purpose....8
4.3 Wazuh Manager and Dashboard Architecture....8
4.4 Snort and Suricata Comparison....9
4.5 Nmap and Wireshark....9
4.6 Installed Tools Summary....9
4.7 Suricata Configuration Checks....9
5. Wazuh Security Monitoring....10
5.1 What an Analyst Monitors....10
5.2 Reading a Wazuh Alert....10
5.3 Analyst Workflow....10
5.4 Key Security Events to Monitor....10
6. Network Intrusion Detection....12
6.1 IDS and IPS....12
6.2 Snort and Suricata....12
6.3 How Network Traffic Is Inspected....12
6.4 Snort, Suricata and Wazuh Detection Comparison....12
6.5 Why Network IDS and Host SIEM Detect Different Things....13
7. Safe Security Investigation: Multiple Failed Logins Followed by Success....14
7.1 Investigation Workflow....14
7.2 Investigation Steps and Data Sources....14
7.3 Scenario Timeline....14
7.4 Assessment and Classification....15
8. Indicators of Compromise (IOC) Analysis....16
9. Alert Classification....17
9.1 Severity Categories....17
9.2 Representative Security Events....17
10. Incident Response Lifecycle....19

11. Incident Ticket..... 20
12. SOC Investigation Playbooks.....21
13. Challenges and Limitations..... 23
14. Findings and Recommendations..... 23
15. Learning Outcomes and Conclusion..... 23
16. References..... 24

1. Executive Summary

1.1 Purpose of the Assessment

This report documents the Week 11 internship assessment on SOC threat detection, alert correlation and incident response. It explains how a SOC analyst combines host-based telemetry (Wazuh) with network intrusion detection (Snort or Suricata), investigates suspicious activity, assigns severity, and follows a structured incident response procedure.

1.2 Learning Objectives

- Explain alert correlation and distinguish events, alerts and incidents.
- Describe how Wazuh and network IDS tools detect different aspects of the same activity.
- Perform a structured investigation of multiple failed logins followed by a successful login.
- Identify and interpret Indicators of Compromise (IOCs).
- Classify alerts by severity and apply the incident response lifecycle.
- Produce an incident ticket and three investigation playbooks.

1.3 Tools and Lab Environment

The lab runs on Ubuntu 26.04.1 LTS (Resolute Raccoon) inside Oracle VirtualBox, with the Linux user vboxuser. During the assessment the VM had approximately 1.6 GiB of available RAM and approximately 12 GB of free disk space. Tools: Wazuh Agent 4.14.8, Suricata 8.0.0, Nmap and Wireshark.

1.4 Progress Summary

Table 1 lists the tools installed in the lab and the role each plays in this assessment. The report covers SOC concepts, monitoring, investigation, IOC analysis, alert classification, incident response, a sample incident ticket and three playbooks.

Table 1: Lab tools and purpose

Tool	Version / status	Purpose in this assessment
Ubuntu	26.04.1 LTS (Resolute Raccoon)	Guest operating system in VirtualBox
Wazuh Agent	4.14.8 installed	Collects logs and file integrity data from the endpoint and forwards them to a Wazuh Manager
Suricata	8.0.0 RELEASE installed	Network intrusion detection engine
Snort	Covered in comparison	Network IDS used for the Snort and Wazuh comparison
Nmap	Installed	Network scanning to generate controlled test traffic
Wireshark	Installed	Packet capture and protocol analysis

2. Introduction to the Security Operations Centre (SOC)

2.1 SOC Overview

A Security Operations Centre is the team, process and technology set responsible for continuously monitoring an organisation's systems, detecting threats, investigating alerts and coordinating response. A SOC typically ingests logs from endpoints, servers, network devices and cloud services into a SIEM (Security Information and Event Management) platform such as Wazuh, and complements it with network sensors such as Snort or Suricata.

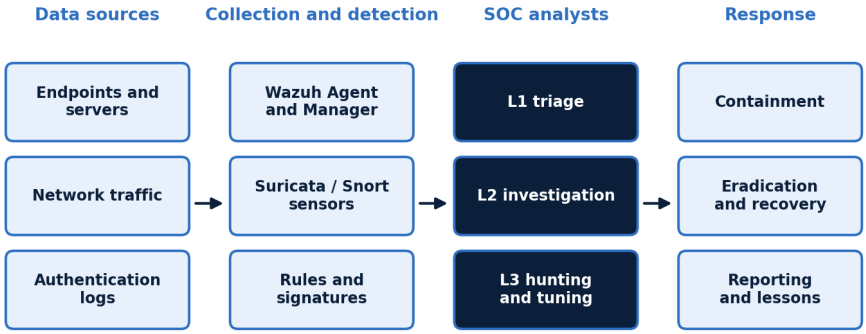


Figure 1: How a SOC turns data into response

2.2 Responsibilities of SOC Analysts

- Continuously monitor dashboards, alert queues and system health.
- Triage alerts and decide whether they are benign, suspicious or malicious.
- Correlate events across hosts, users and network sensors.
- Document findings in tickets with timestamps and evidence.
- Escalate confirmed or high-risk activity and support containment.
- Tune detection rules to reduce false positives and close visibility gaps.
- Maintain playbooks and contribute to post-incident reviews.

2.3 Analyst Tiers

Table 2: SOC analyst tier responsibilities

Tier	Focus	Typical activities	Escalates to
L1 – Triage Analyst	Monitoring and first review	Watch alert queues, validate alerts, check known false-positive patterns, open tickets, follow playbooks	L2 when an alert cannot be explained or appears malicious
L2 – Incident Analyst	Deep investigation	Correlate multiple sources, analyse logs and packets, scope the incident, recommend and perform containment	L3 or incident manager for complex or high-severity incidents
L3 – Senior / Threat Hunter	Advanced analysis	Threat hunting, malware and forensic analysis, detection engineering, rule tuning, lessons-learned leadership	Management, legal, external parties as required

3. Alert Correlation

3.1 What Is Alert Correlation?

Alert correlation is the process of linking related events and alerts, from one or several sources, by shared attributes such as source IP, username, host, time window or behaviour pattern, so that an analyst sees one coherent story instead of many isolated records.

3.2 Why Correlation Matters

- **Reduces noise:** many low-level alerts are consolidated into one investigation.
- **Raises confidence:** agreement between a host log and a network signature strengthens a finding.
- **Reveals attack chains:** reconnaissance, access attempts and post-access activity are connected over time.
- **Prioritises effort:** analysts focus on correlated, higher-risk activity first.

3.3 Event vs Alert vs Incident

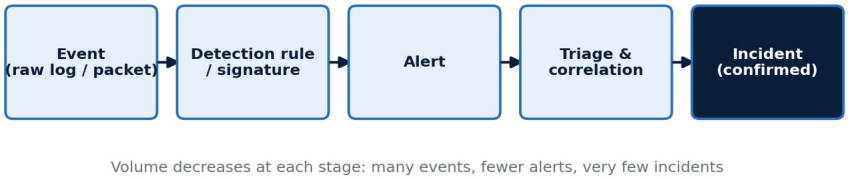


Figure 2: Progression from event to alert to incident

Table 3: Event, alert and incident compared

Term	Definition	Example (generic)
Event	Any observable occurrence recorded in a log or captured on the network	A single SSH login record; one ICMP packet
Alert	A notification produced when an event or pattern matches a detection rule or signature	A rule fires for repeated authentication failures
Incident	A confirmed or reasonably suspected event that threatens confidentiality, integrity or availability and requires response	Confirmed unauthorised access to an account

3.4 True Positive vs False Positive

Table 4: Alert outcome classification

Outcome	Meaning	Analyst action
True Positive (TP)	The alert correctly identified real malicious or policy-violating activity	Escalate, contain, document
False Positive (FP)	The alert fired but the activity is benign (for example an administrator mistyping a password)	Document reason, consider rule tuning
True Negative (TN)	No alert and no malicious activity	None
False Negative (FN)	Malicious activity occurred but no alert fired	Identify visibility gap, improve detection

A finding is only classified as TP or FP when evidence supports that conclusion. Otherwise it remains **under investigation**.

3.5 Indicators of Compromise (IOCs)

An IOC is an observable artefact that suggests a system may have been compromised or targeted, such as an IP address, username, file path or hash, domain, port, protocol or timestamp pattern. IOCs support detection, scoping and sharing of threat information. Section 8 analyses each IOC type.

3.6 Threat Detection vs Incident Response

Table 5: Threat detection and incident response compared

Aspect	Threat Detection	Incident Response
Goal	Find suspicious or malicious activity	Limit damage, remove the threat, restore operations
Inputs	Logs, network traffic, rules, signatures, threat intelligence	Confirmed or suspected incident, analysis results, playbooks
Typical outputs	Alerts, triage decisions	Containment actions, recovery, report, lessons learned
Tools in this lab	Wazuh Agent (host), Suricata (network)	Incident ticket DG-SOC-001 template, playbooks

3.7 Example: Correlating Multiple Security Events

The following example shows how individually weak signals combine into a strong finding.

Table 6: Correlation of multiple security events

Step	Source	Observation	Interpretation alone
1	Network IDS	Many connection attempts from one external address to the SSH port	Possible scan or brute-force attempt
2	Host SIEM	Repeated authentication failures for one account from the same address	Possible password guessing
3	Host SIEM	Successful login for that account from the same address	Possible account compromise
4	Host SIEM	New file or privilege change shortly after login	Possible post-compromise activity

Correlated by source address, account and time window, these four records support a hypothesis of brute-force followed by account compromise, which warrants escalation and verification.

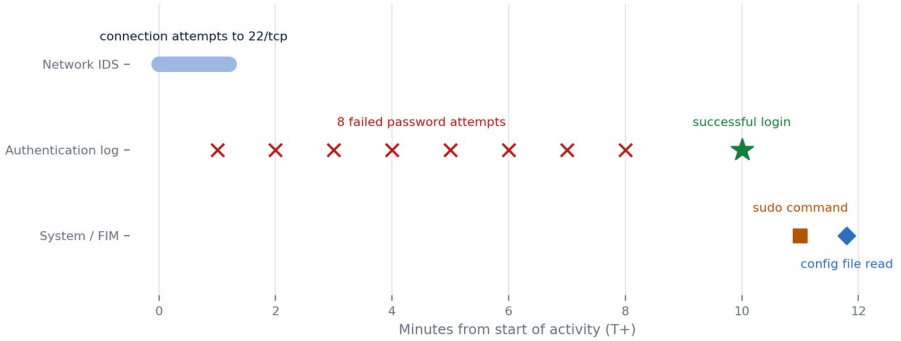


Figure 3: Correlated scenario timeline across network, authentication and system sources

4. Lab Environment and Tool Configuration

4.1 VirtualBox and Ubuntu Architecture

Oracle VirtualBox hosts a single Ubuntu 26.04.1 LTS guest. Security tools run inside the guest. The figure below shows the lab architecture.

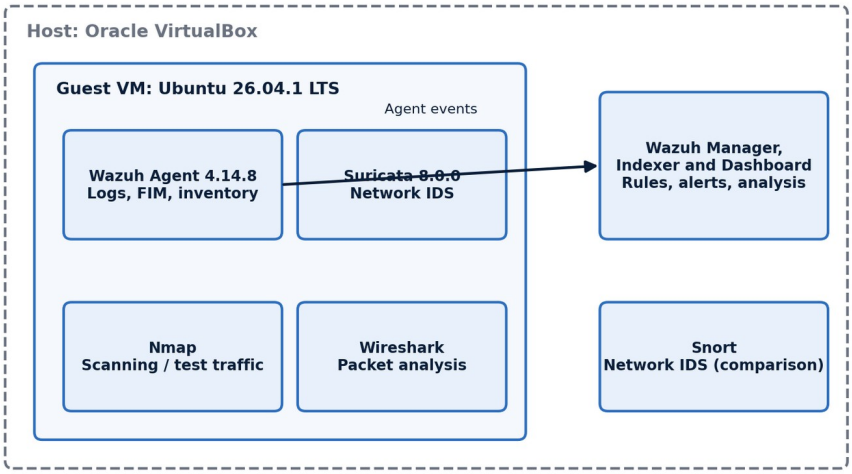


Figure 4: Lab architecture

4.2 Wazuh Agent: Installation and Purpose

The Wazuh Agent (version 4.14.8) was previously installed and its service previously confirmed active. The agent runs on the monitored endpoint and collects log data, performs file integrity monitoring (FIM), inventories software and configuration, and forwards events securely to a Wazuh Manager for analysis. The agent alone does not generate alert records for the dashboard; rule matching happens on the manager.

4.3 Wazuh Manager and Dashboard Architecture

Table 7: Wazuh platform components

Component	Role
Wazuh Agent	Endpoint collector: logs, FIM, inventory, active-response execution
Wazuh Server (Manager)	Receives agent data, decodes events, applies rules, generates alerts, manages agents
Wazuh Indexer	Stores and indexes alerts and events for search
Wazuh Dashboard	Web interface for alerts, agent status, FIM and rule browsing

The Wazuh Manager receives agent data, decodes it, applies rules and generates alerts, while the dashboard presents them to analysts. A full on-premise Wazuh server needs considerably more memory than a small VM, so the official Wazuh requirements should be checked before deployment.

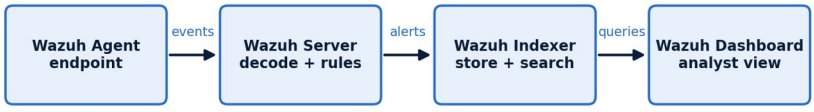


Figure 5: Wazuh data flow from agent to dashboard

4.4 Snort and Suricata Comparison

Table 8: Snort and Suricata compared

Feature	Snort	Suricata
Type	Open-source network IDS/IPS	Open-source network IDS/IPS and network security monitoring engine
Detection method	Signature/rule-based, with preprocessors and inspectors	Signature/rule-based with protocol detection; supports multi-threading
Rule syntax	Snort rules (Snort 3 introduced updates)	Largely Snort-compatible rule syntax with extensions
Output	Alert logs, packet logging	Alert logs and EVE JSON structured output, convenient for SIEM ingestion
Role in this assessment	Compared conceptually with Suricata and Wazuh	Network IDS installed in the lab (8.0.0)

4.5 Nmap and Wireshark

- **Nmap** is a network scanner for host discovery and port/service enumeration. In a SOC lab it generates controlled test traffic (for example a scan of one's own VM) that detection tools can be tested against.
- **Wireshark** is a packet analyser used to inspect captured traffic at protocol level, for example to confirm what a network IDS alert refers to.

Both were previously installed. No scan output or capture from them is presented here.

4.6 Installed Tools Summary

The lab includes Ubuntu 26.04.1 LTS, Wazuh Agent 4.14.8, Suricata 8.0.0, Nmap and Wireshark, as listed in Table 1.

4.7 Suricata Configuration Checks

The following checks are used to validate and tune a Suricata installation.

Table 9: Suricata validation steps

Step	Purpose	Command
1	Read service status and exit reason	systemctl status suricata
2	Read detailed journal entries	journalctl -xeu suricata
3	Validate configuration and rule loading	sudo suricata -T -c /etc/suricata/suricata.yaml -v
4	Confirm capture interface name matches configuration	ip -br link
5	Check memory pressure	free -h
6	Retest and record outcome	sudo systemctl restart suricata, then check status

5. Wazuh Security Monitoring

5.1 What an Analyst Monitors

Table 10: Wazuh monitoring categories and analyst focus

Category	What the analyst reviews	Why it matters
Successful authentication	Account, source address, time, method (for example SSH key or password), unusual hours or locations	A success after failures, or from an unusual source, may indicate compromise
Failed authentication	Number of failures, targeted accounts, source addresses, rate over time	Indicates password guessing or user error
File integrity changes	Path, change type (added, modified, deleted), hash change, user and process if available	Unexpected changes to system or configuration files may indicate tampering or persistence
System events	Service start/stop, privilege use, package changes, account creation	Reveals configuration changes and possible post-compromise activity
Agent status	Connected / disconnected / never connected, last keep-alive, version	A silent agent is a monitoring gap and may signal tampering
Security alerts and rule IDs	Rule ID, rule description, level, rule group, MITRE mapping where present	Rule ID and level drive triage and let analysts search for related alerts

5.2 Reading a Wazuh Alert

Each Wazuh alert contains fields such as timestamp, agent name, rule ID, rule level, rule description, rule groups, and the original log (full_log). Analysts use the rule level as a starting severity and then adjust it using context such as asset criticality and correlated evidence. The rule ID shown in the alert identifies the exact detection logic that fired.

5.3 Analyst Workflow

Table 11: Wazuh monitoring workflow

Step	Analyst action
1	Open the agent list and confirm the agent status is Active and the last keep-alive is recent
2	Filter alerts by agent and time window
3	Filter by rule group (for example authentication failures) and sort by timestamp
4	Open an alert; record rule ID, level, source address, account and full log
5	Review FIM events for the same time window
6	Pivot to related alerts sharing the same source address or account
7	Record the finding and evidence summary in the ticket

5.4 Key Security Events to Monitor

The assignment asks for at least 10 security events to be monitored. The table lists the ten event types a SOC analyst reviews in Wazuh and what is checked for each.

Table 12: Ten security event types monitored by a SOC analyst

#	Event type	Data source	Analyst checks
1	Successful login (SSH or console)	Authentication log	Account, source address, time, login method

#	Event type	Data source	Analyst checks
2	Failed login attempt	Authentication log	Account, source address, reason for failure
3	Multiple failed logins from one source	Correlated authentication alerts	Count, rate, targeted accounts
4	Successful login after failures	Correlated authentication alerts	Same source and account as the failures
5	sudo / privilege use	System / authentication log	User, command, time
6	File integrity change	FIM (syscheck)	Path, change type, hash, user
7	New user account or group change	System log	Who created it and whether it was approved
8	Service start or stop	System log	Service name, who or what triggered it
9	Agent connected / disconnected	Agent status	Last keep-alive, agent version
10	Network IDS alert (Suricata)	EVE JSON / alert log	Signature ID, source, destination, port

6. Network Intrusion Detection

6.1 IDS and IPS

An **Intrusion Detection System (IDS)** inspects traffic or logs and raises alerts but does not block. An **Intrusion Prevention System (IPS)** sits inline and can drop or reject malicious traffic. Detection-only mode is the safer starting point in a lab.

6.2 Snort and Suricata

Both engines match traffic against rules containing a header (action, protocol, addresses, ports) and options (content patterns, flow state, message, rule identifier). A Snort SID or Suricata signature ID uniquely identifies the rule that fired and is recorded as an IOC-supporting field.

6.3 How Network Traffic Is Inspected

Table 13: Network inspection stages

Stage	Description
Capture	The sensor reads packets from a network interface or a capture file
Decode	Packets are parsed into layers (Ethernet, IP, TCP/UDP, ICMP)
Stream and protocol analysis	Flows are reassembled; application protocols (HTTP, DNS, TLS, SSH) are identified
Rule matching	Traffic is compared with loaded rules/signatures
Logging / alerting	Matches are written to alert logs; Suricata can also produce EVE JSON



Figure 6: Network traffic inspection stages

6.4 Snort, Suricata and Wazuh Detection Comparison

Table 14 follows the format requested in the assignment. A tick means the tool typically detects the event when suitably configured; a dash means it normally does not. Severity and analyst finding show how an analyst typically treats each event.

Table 14: Event-by-event detection comparison

Event	Snort Detection	Suricata Detection	Wazuh Detection	Severity	Analyst Finding
Ping (ICMP echo)	✓ (with ICMP rule)	✓ (with ICMP rule)	—	Low	Normal activity unless sweeping many hosts
Port scan	✓	✓	✓ / — (only if host or firewall logs record it)	Medium	Investigate source and authorisation
Login failure	—	—	✓ (authentication logs)	Medium	Authentication event; check volume and source
Login success after failures	—	—	✓ (authentication logs and correlation)	High	Verify legitimacy of the login

Event	Snort Detection	Suricata Detection	Wazuh Detection	Severity	Analyst Finding
File integrity change	—	—	✓ (FIM)	Medium	Verify against approved change

6.5 Why Network IDS and Host SIEM Detect Different Things

- **Different vantage points:** a network IDS sees packets crossing a link; a host agent sees what the operating system recorded.
- **Encryption:** SSH and TLS payloads are encrypted, so a network sensor cannot read login success or failure; the host log can.
- **Local activity:** file changes, sudo use and local logins never cross the network.
- **Scans and probes:** a network sensor sees probe packets even if the host logs nothing.
- **Configuration:** a missing rule, disabled logging or an inactive service means a tool will not alert.

Correlating both views produces the most reliable conclusion, which is why this module compares them.

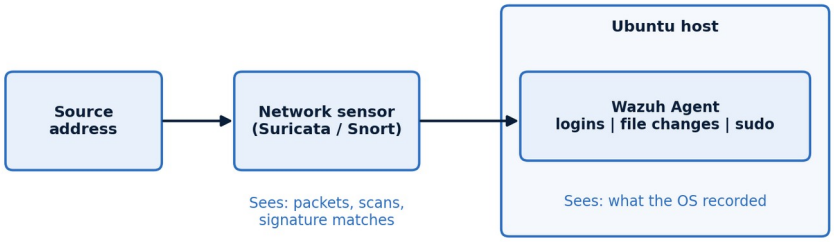


Figure 7: Host and network visibility of the same activity

7. Safe Security Investigation: Multiple Failed Logins Followed by Success

This section demonstrates the investigation method on a Linux host using a scenario built from reserved documentation values such as the address 203.0.113.45.

7.1 Investigation Workflow

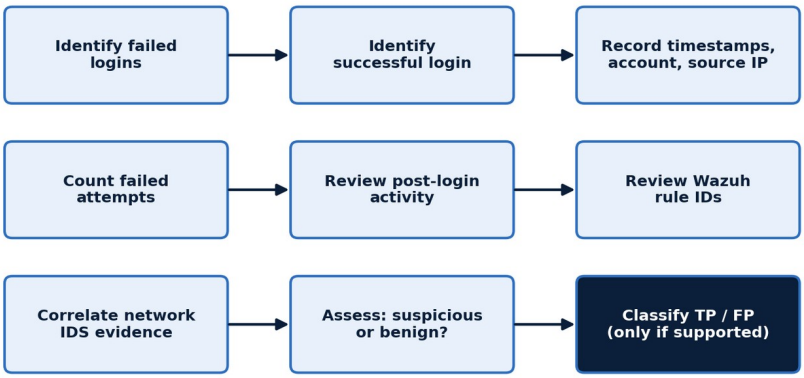


Figure 8: Investigation workflow (read left to right, top to bottom)

7.2 Investigation Steps and Data Sources

Table 15: Investigation questions, data sources and commands

Question	Where to look	Example command (own lab only)
When did the activity start?	Authentication log, Wazuh alert timestamps	sudo grep "Failed password" /var/log/auth.log
Which account was targeted?	Failed login records	journalctl -u ssh --since "1 hour ago"
What is the source IP?	Failed and successful login records	sudo lastb -a; last -a
How many failed attempts?	Count by account and source	grep -c "Failed password" /var/log/auth.log
Was there a successful login?	Accepted-authentication records	sudo grep "Accepted" /var/log/auth.log
What happened afterwards?	Shell history, sudo log, FIM events, new processes	sudo grep sudo /var/log/auth.log; ps aux
Which Wazuh rule fired?	Wazuh dashboard alert details	Dashboard: rule ID, level, groups
Did a network IDS see related traffic?	Suricata or Snort alert log	/var/log/suricata/eve.json

7.3 Scenario Timeline

Table 16: Scenario values

Item	Value
Source IP	203.0.113.45 (reserved documentation address)
Targeted account	demo_user
Start of activity	T+00:00 (relative time)
Failed attempts	Eight failed SSH password attempts within a few minutes
Successful login	T+00:10, same source and account
Post-login activity	Configuration file read, then a privileged command run with sudo

Item	Value
Wazuh rule ID	The ID of the authentication-failure rule shown in the alert
Suricata / Snort SID	The signature ID shown in the network IDS alert

7.4 Assessment and Classification

In this scenario, repeated failures followed by a success from the same source against the same account are suspicious and would be escalated to L2 for verification (for example, contacting the account owner and checking whether the source is authorised). MITRE ATT&CK techniques that may apply are T1110 (Brute Force) and T1078 (Valid Accounts).

Classification

Scenario finding: suspicious, pending verification with the account owner. It would be classified as a true positive only if the owner denies the login or other evidence confirms misuse, and as a false positive if the owner confirms it.

8. Indicators of Compromise (IOC) Analysis

Table 17 lists each IOC type requested by the assignment, with values taken from the scenario in Section 7 and the significance of each indicator.

Table 17: IOC table and significance

IOC type	Scenario value	Significance
IP address	203.0.113.45	Identifies the origin; used for blocking, reputation checks and correlating alerts
Username	demo_user	Shows which identity was targeted or used; reveals compromised or abused accounts
File / path	/etc/ssh/sshd_config	Reveals tampering or persistence; verified by hash and ownership
Domain	example.test	Indicates command-and-control or phishing infrastructure; blocked at DNS
Port	22/tcp	Shows the targeted service; helps identify scan and exploit attempts
Protocol	TCP (SSH)	Shows how the activity travelled; guides which sensor can see it
Timestamp	T+00:00 to T+00:10	Builds the timeline, shows duration and rate, supports correlation
Wazuh Rule ID	Rule ID from the alert	Identifies the exact detection logic; enables searching for related alerts
Snort SID / Suricata signature ID	SID from the IDS alert	Identifies the network signature that fired; links network evidence to host evidence

IOCs are most valuable when combined: an IP address alone may be shared or dynamic, but the same IP, account and time window across two independent sources is strong evidence.

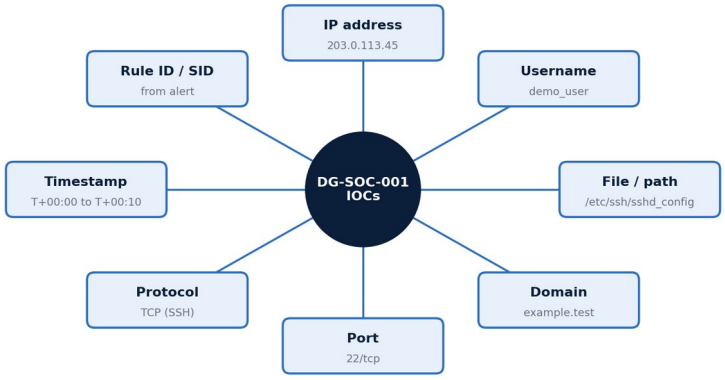


Figure 9: IOC map for incident DG-SOC-001

9. Alert Classification

9.1 Severity Categories

Table 18: Severity categories

Severity	Definition	Typical response
Informational	Normal or expected activity recorded for visibility	No action; retain for context
Low	Minor deviation with minimal risk	Review in routine triage
Medium	Suspicious or policy-violating activity needing investigation	Investigate promptly; may escalate
High	Likely malicious activity or serious risk to an important asset	Immediate investigation; escalate to L2/L3
Critical	Confirmed compromise or severe business impact	Declare incident; immediate containment and management notification



Figure 10: Alert severity scale

9.2 Representative Security Events

The following 15 representative security events are classified by severity with the reasoning for each.

Table 19: 15 representative security events classified by severity

#	Severity	Event (training example)	Reasoning
1	Informational	System boot recorded in system log	Expected operation; context only
2	Informational	Wazuh agent keep-alive received	Normal heartbeat showing the agent is alive
3	Informational	Scheduled package index refresh	Routine maintenance, no risk
4	Low	Single failed login by a known user	Likely typing error; isolated
5	Low	One ICMP echo request from an internal admin host	Normal diagnostics
6	Low	Successful password change by a user	Expected account activity; confirm user initiated
7	Medium	Multiple failed logins from one source	Possible password guessing; needs investigation
8	Medium	Port scan from an unknown internal host	Reconnaissance; authorisation unknown
9	Medium	New user account created outside change window	Could be legitimate but unapproved
10	High	Successful login after many failures from an external source	Possible account compromise
11	High	Unexpected modification of a sensitive system file	Possible tampering or persistence
12	High	Unexpected sudo/root privilege use by a normal account	Possible privilege escalation
13	Critical	Confirmed ransomware or malware execution	Direct impact on integrity and availability
14	Critical	Confirmed data exfiltration to an unknown host	Confidentiality breach with business impact

#	Severity	Event (training example)	Reasoning
15	Critical	Security agent disabled and logs cleared after root access	Active attacker evading detection

10. Incident Response Lifecycle

The lifecycle below follows the NIST incident response guidance and is applied to the selected scenario (multiple failed logins followed by a successful login).

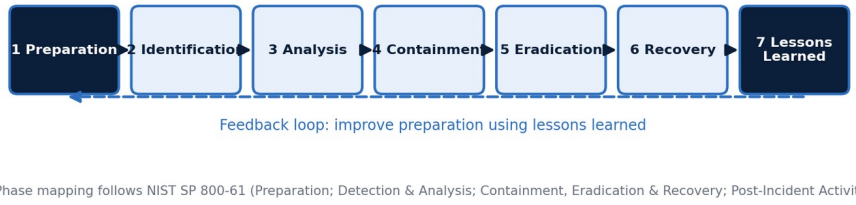


Figure 11: Incident response lifecycle workflow

Table 20: Incident response stages for the selected scenario

Stage	Key questions and actions
1. Preparation	Maintain asset inventory, working agents on all systems, tested log forwarding, tuned rules, playbooks, contact lists, ticketing, backups, and trained analysts
2. Identification	Detect through host authentication alerts and network IDS alerts; confirm that logged activity is real and in scope; open ticket
3. Analysis	Collect evidence: log excerpts, timestamps, account, source IP, rule IDs, post-login activity, FIM changes; correlate sources; determine scope and impact
4. Containment	Short term: block source IP at the firewall, disable or lock the affected account, terminate suspicious sessions, isolate the host if needed. Preserve evidence first
5. Eradication	Remove the root cause: reset credentials, remove unauthorised keys or accounts, revert unapproved changes, patch weaknesses, harden SSH (key-only login, rate limiting)
6. Recovery	Restore from known-good state if required, re-enable services, monitor closely for recurrence, verify system integrity before returning to production
7. Lessons Learned	Review timeline, what worked, what was missed; update rules, playbooks and training; track improvement actions

11. Incident Ticket

Table 21: SOC incident ticket DG-SOC-001

Field	Entry
Incident ID	DG-SOC-001
Title	Multiple failed logins followed by a successful login
Date and time	T+00:00 to T+00:10
Severity	High
Affected system	Ubuntu 26.04.1 LTS lab VM (user vboxuser)
Source IP	203.0.113.45
User / account	demo_user
Detection source	Wazuh / Snort-Suricata
Description	Eight failed SSH logins for demo_user from one source, followed by a successful login from the same source and a privileged command.
Evidence	Authentication log entries (failed and accepted), Wazuh alert details, network IDS alert log
IOCs	203.0.113.45; demo_user; /etc/ssh/sshd_config; 22/tcp; TCP (SSH); see Section 8
Investigation findings	Pattern is consistent with password guessing followed by a successful login; legitimacy of the login must be verified with the account owner
Actions taken	Source IP reviewed and blocked if unauthorised, account owner contacted for confirmation, session activity reviewed
Current status	Investigating
Recommendations	Verify account legitimacy, block unauthorised sources, enforce key-based SSH, tune detection rules

12. SOC Investigation Playbooks

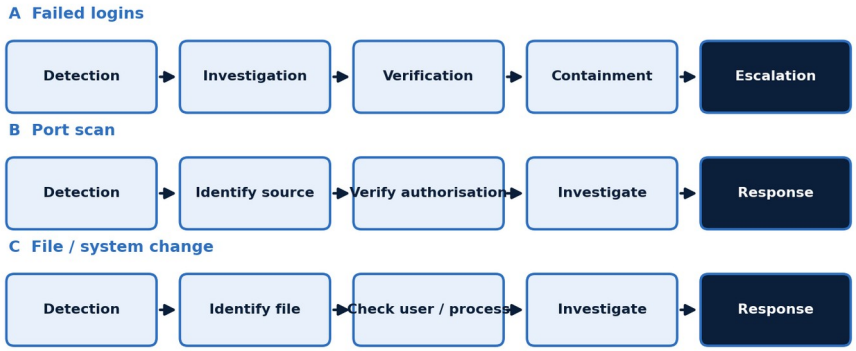


Figure 12: Overview of the three response playbooks

12.1 Playbook A: Multiple Failed Logins

Table 22: 12.1 Playbook A: Multiple Failed Logins

Phase	Actions
Detection	Alert for repeated authentication failures; note rule ID, source address, account, time window
Investigation	Count failures; list targeted accounts; check whether a success followed; review post-login activity; look for matching network IDS alerts
Verification	Confirm with the account owner; check whether source is a known admin host, VPN or user location; check for typing errors or a service misconfiguration
Containment	If unauthorised: block source IP, lock or reset the account, terminate sessions, preserve logs
Escalation	Escalate to L2 if any success occurred, privileged accounts were targeted, or activity continues; open or update the ticket

12.2 Playbook B: Port Scan

Table 23: 12.2 Playbook B: Port Scan

Phase	Actions
Detection	Network IDS alert or logs showing many connection attempts to different ports or hosts
Source IP identification	Record source address, internal or external, and first and last seen times
Port and protocol analysis	List ports probed and protocols (TCP, UDP, ICMP); note whether sensitive services were targeted
Verification	Check whether the scan is authorised (for example a scheduled vulnerability scan or an intern's Nmap test)
Containment / escalation	If unauthorised: block the source, review exposure of probed services, search for follow-on login attempts; escalate if exploitation is suspected

12.3 Playbook C: Suspicious File or System Change

Table 24: 12.3 Playbook C: Suspicious File or System Change

Phase	Actions
Detection	File integrity alert on a monitored path; note rule ID and change type
File / path verification	Confirm path, ownership, permissions and whether it is a sensitive file
User and timestamp identification	Identify the account and process responsible and when the change occurred

Phase	Actions
Hash comparison (where available)	Compare the current hash with the baseline or a trusted source
Investigation	Check for matching package updates or approved change; review logins and commands around that time
Containment / escalation	If unapproved: restore the file from a trusted source, isolate the host if compromise is likely, escalate to L2

13. Challenges and Limitations

Table 25: Challenges encountered

Challenge	Detail
Wazuh Cloud trial ended	The earlier cloud manager is no longer available, so a new manager is needed for central alert monitoring
Snort package	The snort package was not found in the Ubuntu 26.04 package index, so Suricata is used as the network IDS
Suricata service startup	Suricata 8.0.0 installed successfully; service startup requires configuration troubleshooting (Section 4.7)
Limited resources	Approximately 1.6 GiB RAM, no swap space and approximately 12 GB free disk limit how many tools can run at once

14. Findings and Recommendations

Findings. The assessment covered correlation concepts, monitoring workflows, a structured investigation, IOC analysis, severity classification, incident response, a sample ticket and three playbooks. The main constraints were tool availability and limited VM memory.

- **Recommendation 1:** Troubleshoot the Suricata service using the validation steps in Section 4.7.
- **Recommendation 2:** Obtain a Wazuh manager (new trial or suitably sized host) for central alert monitoring.
- **Recommendation 3:** If Snort is required, check the official Snort 3 installation options for Ubuntu.
- **Recommendation 4:** Increase VM memory or add swap, and run only the required tools.
- **Recommendation 5:** Generate controlled traffic against the own lab only (Nmap, failed logins) and record the resulting alerts.
- **Recommendation 6:** Tune detection rules to reduce false positives.

15. Learning Outcomes and Conclusion

- **Technical knowledge:** Wazuh architecture (agent, manager, indexer, dashboard), IDS vs IPS, Snort vs Suricata, role of Nmap and Wireshark.
- **SOC investigation concepts:** event-alert-incident progression, TP/FP classification, IOC analysis, tiered analyst roles.
- **Alert correlation:** linking host and network evidence by source, account and time.
- **IDS/SIEM architecture:** why different sensors see different aspects of the same activity.
- **Incident response:** the seven-stage lifecycle, ticket documentation and playbooks.
- **Honest reporting:** separating installed, running, observed, alerted and verified states.

Conclusion. This assessment built the analytical foundation needed for a SOC role: correlation logic, structured investigation, severity classification, incident response and documentation. **Future improvements:** complete the Suricata setup, connect the Wazuh Agent to a manager, tune rules, and run the investigation as a live lab exercise.

16. References

Table 26: Official documentation and references

Source	Link
Wazuh Documentation	https://documentation.wazuh.com/
Suricata Documentation	https://docs.suricata.io/
Snort Documentation	https://docs.snort.org/ and https://www.snort.org/
MITRE ATT&CK	https://attack.mitre.org/
NIST SP 800-61 Rev. 3, Incident Response Recommendations and Considerations for Cybersecurity Risk Management	https://csrc.nist.gov/pubs/sp/800/61/r3/final
Ubuntu Documentation	https://documentation.ubuntu.com/ and https://ubuntu.com/server/docs
Oracle VirtualBox Manual	https://www.virtualbox.org/manual/
Nmap Reference Guide	https://nmap.org/book/man.html
Wireshark Documentation	https://www.wireshark.org/docs/

Appendix A: Glossary

Table 27: Glossary of SOC terms

Term	Meaning
SOC	Security Operations Centre
SIEM	Security Information and Event Management platform
IDS / IPS	Intrusion Detection / Prevention System
FIM	File Integrity Monitoring
IOC	Indicator of Compromise
TP / FP	True Positive / False Positive
SID	Signature identifier of a Snort or Suricata rule
EVE JSON	Suricata's structured JSON event output
MITRE ATT&CK	Knowledge base of adversary tactics and techniques
Playbook	Documented step-by-step response procedure
Containment	Actions limiting spread or impact of an incident